

Data Exfiltration via DNS Tunneling response

Data Exfiltration · **Critical** severity · SOC IR Playbook

Incident type	Covert Channel - Data Exfiltration
Severity	Critical
Priority	Critical
Detection sources	DNS logs, SIEM, NDR, Threat intelligence, Endpoint alerts, Zeek, Suricata

Scenario

An attacker uses DNS as a communication channel to exfiltrate data or maintain command and control. DNS tunnelling disguises malicious payloads or stolen data inside DNS queries, bypassing traditional detection since DNS traffic is usually allowed.

MITRE ATT&CK

T1048.003, T1071.004, T1568.002

Preparation

Enable detailed DNS logging From DNS resolvers and forwarders (e.g., BIND, Windows DNS, Unbound)
Implement DNS inspection Use NDR (e.g., Corelight, Darktrace), firewall rules and pattern matching Monitor for anomalous DNS activity Large TXT queries, long domain names, unusual frequencies Block known tunnelling tools e.g., Iodine, DNScat2, DnsExfiltrator via threat intelligence Enforce least privilege on outbound DNS Allow only authorised DNS resolvers from internal assets

Detection & Analysis

Detect abnormal DNS patterns Long subdomain lengths, frequent queries to rare domains, base64 encoding Review DNS logs Identify queried domains, query types (e.g., TXT, NULL) and endpoints involved Correlate with asset behaviour Determine if endpoints sending queries also show signs of compromise Validate domain ownership Check if the suspicious domains are attacker-controlled or registered recently

Containment

Block suspicious domains At DNS resolver, firewall and proxy level Isolate affected hosts Disconnect from network to stop ongoing exfiltration Redirect DNS traffic Force all outbound DNS through monitored internal DNS servers Alert internal stakeholders IT, security and management should be informed immediately

Eradication

Remove tunnelling tools or malware From endpoints using EDR or forensic analysis Patch exploited vulnerabilities If attacker gained access through known weaknesses Clean persistence mechanisms Check for scheduled tasks, registry changes or startup scripts Review DNS configurations Ensure no external DNS bypasses exist on endpoints or servers

Recovery

Restore network connectivity Once system is verified to be clean and containment controls are in place Resume DNS services Enforce forwarding through secure DNS infrastructure with inspection Revalidate affected systems Perform full scan and traffic monitoring on previously infected hosts Update threat detection rules Enhance SIEM, NDR and firewall rules with new indicators and patterns

Lessons Learned & Reporting

Document full exfiltration path Identify what data was targeted or lost, how and when Update incident response plans Add DNS-specific detection and response protocols Improve DNS visibility Enforce structured DNS logging and analytics across all environments Report breach if applicable Under PDPA, GDPR, HIPAA or industry-specific regulations Share IOCs and findings Internally and with external threat intelligence communities (e.g., ISACs)

Tools typically involved

DNS Logging Platforms (e.g., Infoblox, Bind logs, Windows DNS logs); NDR (e.g., Corelight/Zeek, Darktrace, ExtraHop); SIEM (e.g., Splunk, Sentinel, QRadar); EDR (e.g., CrowdStrike, Cortex XDR); Threat Intelligence (e.g., Recorded Future, MISP, AbuseIPDB); Firewall and proxy logs

Success metrics (SLA targets)

Detection Time <15 minutes from abnormal DNS pattern Containment Time <30 minutes from confirmation Data Loss Impact Report Within 48 hours (or regulatory timeframe) DNS Logging Coverage 100% of egress DNS activity logged and monitored Incident Review Completion Within 72 hours post-resolution